

GUARDIANES DE LO INTANGIBLE

G. Monzon Flores

7690-20-20745 Universidad Mariano Gálvez

7690 Seminario de Tecnología de Información

gmonzonfl@miumg.edu.gt

Resumen

El presente artículo analiza la relación y las diferencias entre ciberseguridad, seguridad informática y seguridad de la información, con el propósito de identificar por qué las organizaciones deben proteger sus datos mediante un enfoque que incluya tecnología, procesos y personas. Se realizó una revisión de documentación técnica y normas actuales publicadas por el Instituto Nacional de Estándares y Tecnología (NIST), la Agencia de Ciberseguridad y Seguridad de Infraestructura (CISA) y la Organización Internacional de Normalización (ISO). Como resultado, se identificó que la seguridad de la información tiene un alcance amplio, pues protege datos sin importar su soporte; la seguridad informática se concentra en los activos y sistemas computacionales; y la ciberseguridad atiende los riesgos asociados a redes, servicios digitales y comunicaciones electrónicas. El análisis también permitió reconocer que medidas aisladas, como instalar un antivirus o usar contraseñas complejas, resultan insuficientes cuando no existe gestión de riesgos, capacitación, control de accesos, respaldo de información y respuesta ante incidentes. Se concluye que una protección efectiva no depende solamente de herramientas avanzadas, sino de definir responsabilidades, priorizar los activos críticos y mantener controles verificables que permitan prevenir, detectar, responder y recuperarse de los incidentes.

Palabras clave: ciberseguridad, seguridad informática, seguridad de la información, gestión de riesgos, controles de seguridad

Desarrollo del tema

La dependencia de los sistemas digitales ha convertido la seguridad en una condición básica para la continuidad de cualquier organización. Una institución educativa administra expedientes y calificaciones; un banco procesa transacciones; una empresa conserva datos de clientes, contratos y estrategias comerciales. Si esa información se revela, se modifica sin autorización o deja de estar disponible, el problema no es únicamente técnico: puede detener operaciones, causar pérdidas económicas y afectar la confianza de las personas.

Aunque en la práctica suelen usarse como sinónimos, ciberseguridad, seguridad informática y seguridad de la información no poseen exactamente el mismo alcance. La seguridad de la información es el concepto más amplio. Su objetivo es proteger la confidencialidad, integridad y disponibilidad de la información, ya sea que esta se encuentre en una base de datos, un documento impreso, una conversación, una memoria USB o un servicio en la nube. El NIST (s.f.) define esta protección frente al acceso, uso, divulgación, alteración, interrupción o destrucción no autorizados. Por ello, también son medidas de seguridad guardar bajo llave un expediente físico, restringir quién puede fotografiarlo y destruirlo correctamente cuando ya no se necesita.

La seguridad informática se enfoca principalmente en los recursos tecnológicos que procesan, almacenan o transmiten información. Incluye servidores, computadoras, aplicaciones, bases de datos, redes y dispositivos móviles. Desde esta perspectiva, aplicar actualizaciones, configurar permisos, proteger una red inalámbrica, realizar copias de seguridad y corregir vulnerabilidades son controles que reducen la posibilidad de que un sistema sea comprometido. No obstante, proteger únicamente la

infraestructura sería insuficiente si un usuario autorizado puede descargar información sensible sin una necesidad justificada o si una persona comparte sus credenciales mediante un engaño.

La ciberseguridad abarca la protección del entorno digital interconectado, especialmente frente a amenazas que utilizan redes, servicios de Internet o comunicaciones electrónicas. Incluye ataques como el robo de credenciales, el fraude por correo electrónico, el secuestro de datos mediante *ransomware* y la interrupción deliberada de servicios. Su finalidad no consiste en prometer que nunca ocurrirá un incidente, algo poco realista en sistemas complejos, sino en administrar el riesgo y reducir tanto la probabilidad como el impacto de una intrusión.

La relación entre los tres conceptos puede entenderse a partir de la información que se desea proteger. La seguridad de la información define el valor y las propiedades que deben conservarse; la seguridad informática aplica controles sobre los activos tecnológicos; y la ciberseguridad responde a las amenazas del espacio digital. Esta distinción es útil porque evita una visión limitada donde todo se resuelve comprando software. Un ataque puede iniciar con una falla técnica, pero también con una contraseña reutilizada, una llamada falsa al personal o un procedimiento sin revisión.

La confidencialidad, integridad y disponibilidad constituyen la base para evaluar si la información está protegida. La confidencialidad limita el acceso a quienes están autorizados; la integridad busca que los datos sean exactos y no se alteren indebidamente; y la disponibilidad permite que usuarios autorizados accedan a ellos cuando los necesitan. Por ejemplo, cifrar una base de datos ayuda a la confidencialidad, registrar cambios ayuda a comprobar la integridad y mantener respaldos probados contribuye a recuperar la disponibilidad después de un incidente. Las tres propiedades deben equilibrarse: un control excesivamente restrictivo puede impedir que un trabajador realice una tarea urgente, mientras que permisos demasiado amplios aumentan el riesgo de exposición.

Para llevar estos principios a la práctica se necesita gestionar riesgos. Primero se deben identificar los activos importantes, los datos que contienen, las amenazas posibles y las vulnerabilidades existentes. Luego se priorizan los riesgos según el daño que podrían ocasionar y se seleccionan controles proporcionales. ISO (2022) plantea que un Sistema de Gestión de Seguridad de la Información permite establecer, implementar, mantener y mejorar de manera continua este proceso. Esto significa que la seguridad no debe depender de una acción puntual ni de una persona que “sabe de computadoras”, sino de políticas, responsables, procedimientos y revisiones periódicas.

El Marco de Ciberseguridad 2.0 del NIST (2024) organiza la gestión del riesgo en seis funciones: gobernar, identificar, proteger, detectar, responder y recuperar. Gobernar implica establecer responsabilidades, políticas y prioridades; identificar supone conocer activos, riesgos y dependencias; proteger reúne controles como autenticación multifactor, privilegios mínimos, cifrado y capacitación. Detectar requiere registros, monitoreo y alertas que permitan reconocer actividad anómala. Responder y recuperar incluyen contener el incidente, comunicarlo, restaurar servicios y aprender de lo ocurrido. La existencia de estas últimas funciones es importante: una organización preparada no solo intenta bloquear ataques, también sabe qué hacer cuando una defensa falla.

Algunos controles ofrecen una mejora considerable sin requerir una infraestructura excesivamente costosa. La autenticación multifactor reduce el daño de una contraseña robada; el principio de mínimo privilegio limita el acceso a lo estrictamente necesario; las actualizaciones corrigen vulnerabilidades conocidas; y las copias de seguridad desconectadas o protegidas ayudan a recuperarse ante un secuestro de datos. La CISA (2025) recomienda establecer prácticas básicas comunes de protección, entre ellas asegurar cuentas, dispositivos, datos y procesos de recuperación. Sin embargo, los controles técnicos deben acompañarse de capacitación continua, porque el personal puede identificar intentos

de suplantación, reportar comportamientos sospechosos y evitar que un error cotidiano se convierta en una brecha mayor.

La seguridad también debe considerarse desde el diseño de un sistema. En lugar de agregar permisos, registros y cifrado cuando el software ya está terminado, conviene definir desde el inicio qué datos son sensibles, quién puede acceder a ellos, cómo se conservarán las evidencias de las operaciones y cuál será el procedimiento ante una falla. Esta práctica permite crear aplicaciones más confiables y facilita demostrar que los controles responden a una necesidad real. La tecnología evoluciona y las amenazas cambian, por lo que la seguridad es un proceso de mejora continua, no una casilla que se marca una vez y se olvida en producción.

Observaciones y comentarios

Durante el análisis se observó que una de las principales debilidades es reducir la seguridad a la compra de un antivirus o de un dispositivo de red. Estas herramientas son útiles, pero no corrigen permisos excesivos, respaldos no verificados ni decisiones inseguras de los usuarios. También existe el riesgo de aplicar controles sin evaluar el activo que se protege, lo que puede aumentar costos sin disminuir un riesgo relevante. Como mejora, toda organización debería mantener un inventario mínimo de activos y datos críticos, definir responsables y probar periódicamente tanto sus respaldos como su respuesta ante incidentes.

Conclusiones

1. La seguridad de la información protege los datos en cualquier soporte, mientras que la seguridad informática y la ciberseguridad se enfocan especialmente en los recursos tecnológicos y el entorno digital interconectado.
2. La confidencialidad, integridad y disponibilidad permiten evaluar qué debe protegerse y qué consecuencias tendría una falla de seguridad.
3. La gestión de riesgos debe orientar los controles, ya que no todos los activos requieren la misma protección ni producen el mismo impacto.
4. La prevención no basta: la detección, la respuesta y la recuperación son necesarias para mantener la continuidad ante incidentes inevitables.
5. Una estrategia efectiva integra tecnología, procesos definidos y personas capacitadas, en lugar de depender de una herramienta aislada.

Bibliografía

Cybersecurity and Infrastructure Security Agency. (2025). *Cybersecurity performance goals*. <https://www.cisa.gov/cybersecurity-performance-goals-cpgs>

International Organization for Standardization. (2022). *ISO/IEC 27001:2022: Information security, cybersecurity and privacy protection — Information security management systems — Requirements*. <https://www.iso.org/standard/27001>

National Institute of Standards and Technology. (2024). *The NIST Cybersecurity Framework (CSF) 2.0*. <https://doi.org/10.6028/NIST.CSWP.29>

National Institute of Standards and Technology. (s.f.). *Information security*. Computer Security Resource Center glossary. https://csrc.nist.gov/glossary/term/information_security

Repositorio

<https://github.com/DaniSaurioM/ForosAcademicos-Seminario>